

To: Mr. Author Dent, Data Protection Officer, Great New Games

Subject: Guidance on GDPR Notification Obligations Following Data Breach

Dear Mr. Dent,

Thank the client for reaching out. I understand 4,000 customer records were exposed, in an unencrypted form for 6 days. This included personal details such as addresses and credit card information. I also appreciate your concern about reputational risk and the potential impact on customers. This type of incident can raise concerns not only about regulatory compliance but also about customer confidence. Breaches involving payment information often receive attention from regulators, financial institutions, and even the press. Acting quickly and transparency will help show that Great New Games is taking the matter seriously and prioritizing customer protection.

Legal Assessment

Under the GDPR, a “personal data breach” is defined as any accidental or unlawful disclosure, access, loss, or alteration of personal data. In this situation, unencrypted credit card and personal information was available publicly, even if only for a limited period. That means this incident qualifies as a personal data breach.

It may help to outline a few terms from the law:

- A controller is the organization that decides how and why personal data is processed. In this case, Great New Games is the controller.
- Processing means anything done with personal data, from collecting and storing it, to disclosing it or making it available.
- A personal data breach includes any situation where personal data is exposed, even if there is no evidence it was misused.

Because the data here was unencrypted and involved payment information, the risk is high. The ICO highlights encrypting as a strong safeguard, but since it was not in place, we must assume exposure could cause harm.

Importantly, under GDPR it does not matter whether is proof that a third part accessed the information. The fact that it was publicly available in unencrypted form is enough to qualify as a breach.

Notification Obligations

The GDPR sets out two main obligations in these situations.

- Supervisory Authority (ICO) or relevant DPA):

Under Article 33, the breach must be reported to the supervisory authority within 72 hours of becoming aware of it. That clock starts from the time the company discovered the problem, now when the breach began. If notification cannot be made within 72 hours, reason for the delay must be given. The notification itself needs to include:

- The nature of breach.
- Categories/number of data subjects.
- Contact info of DPO.
- Likely consequence of the breach.
- Measures taken or planned to address the breach.

Even when a breach is not reported, the GDPR requires companies to keep an internal log of every incident. That log should record the facts, the effects, and what steps were taken. This demonstrates compliance and helps if regulators ask questions later.

The ICO has emphasized that even a late or incomplete notification is better than silence. If a company cannot gather all details within 72 hours, it should submit what it has and provides updates as more information becomes available.

- Affected Individuals (customers):

Under Article 34, of the GDPR, if the breach is likely to result in a high-risk individuals' rights and freedoms, you are required to notify the affected individuals directly and without undue delay. This communication should be clear, accessible, and avoid technical language. It should explain what happened, what categories of information were involved, what protective measures have already been taken, and what practical steps the customer can take to minimize potential harm. In practice, this might include advising them to monitor bank accounts, change passwords, or contact their payment provider.

There are exemptions, for example: if the data had been encrypted or otherwise made unreadable, customer notification might not be required. Since the data here was exposed in plain text, those exemptions don't apply.

Several regulators have stressed that notifying customers early often reduces overall complaints and regulatory scrutiny. In other words, clear and proactive communication can work in the company's favor by showing a commitment to accountability.

Risk of Non-Compliance

Failing to meet these notification obligations can result in significant fines. Under the GDPR, breaches of Articles 33 and 34 may expose Great New Games to administrative fines of up to €10 million or 2% of global annual turnover, whichever is higher. For more

severe breaches involving deliberate neglect, fines can reach €20 million or 4% of turnover. These figures highlight the importance of prompt compliance.

In addition to financial penalties, there is a very real risk of reputational harm. Regulators may publicly name organizations that fail to notify, and customers often lose trust more quickly when they discover breaches through the media rather than directly from the company.

Next Steps

1. Notify the ICO (or relevant supervisory authority) immediately to meet the 72-hour deadline.
2. Prepare clear communication for the 4,000 affected customers, explaining the breach and the protections now in place. Consider offering a FAQ or helpline so customers can get quick answers.
3. Document every detail of the incident:
 - a. What happened
 - b. When it was discovered
 - c. How was it fixed
 - d. What safeguard are being implemented.

This record should be kept even after notifications are made.

4. Review internal processes going forward, encryption of sensitive data, access logging, and breach response planning should all be strengthened. The ICO notes that organizations that show proactive improvement often receive more favorable treatment.

I am available to support drafting both the notification to the authority and the customer communications. I can also provide template language, prepare a readiness checklist, or help review your internal processes and assist with next-steps planning. Taking these steps now will help ensure compliance with GDPR, minimize risk of enforcement, and demonstrate good faith to both regulators and customers.

I look forward to working with you on this and ensuring Great New Games is well-positioned to comply with its obligations.

Kind regards,

Natascha Martin

Clifford Chance, LLP